2 · Cybersecurity risk assessment

The cybersecurity risk assessment decides which Annex I Part I requirements apply to a product and records how each is met. Art 13(2)-(4) require it before placing on the market, documented and kept up to date during the support period. It is filed as Annex VII pt 3 of the technical documentation, with a justification for every requirement not applied.

At a glance

Item	Detail
Legal basis	Art 13(2)-(4); Annex I Part I; Annex VII pt 3; recital 55
Needed for	Deciding Part I applicability; Annex VII pt 3; the "adequate analysis and assessment of the risks" a notified body examines under Module B (Annex VIII Part II pt 3.3)
Owner	Product security officer
Approver	Head of product security; product owner co-signs residual-risk acceptance
When to create	At design, after Template 1 and before the release gate
When to update	On every trigger listed below, throughout the support period (Art 13(3))
Retention	Every version, 10 years after placing or the support period, whichever is longer (Art 13(13))
Feeds	Template 4 (Annex VII pt 3); Template 6 (Annex II pt 5 residual-risk information); Template 10 (baseline for modification tests); Template 3 (expected time in use)

How to complete

1. Pull the boundary, intended purpose and class from Template 1. Choose a method and record why; none is mandated (Commission FAQ section 4.1).

2. Draw the data-flow diagram with trust boundaries, including both ends of each RDPS link.
3. List assets in three classes, run the threat method per flow and asset, and rate each risk.
4. Select controls and trace each to the Part I requirement it serves. Fill the applicability table.
5. Record residual risk per requirement and any reliance on user information.
6. Sign off, version the document and register the update triggers.

Template

Part A: method and context

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Assessment ID and version	[RA-ID], [version], [date], [product or family]	Annex VII pt 3	RA-L2 v1.0, 31 Oct 2026, L2 family (3 SKUs)
Method and reason	[Method(s) used and why]	Commission FAQ section 4.1	BSI TR-03183-1 structure with STRIDE on the data-flow diagram
Product context	[Template 1 record reference]	Art 13(3)	CR-L2-01: lock, app, access-management cloud
Intended purpose and reasonably foreseeable use	[Purpose; foreseeable use and misuse]	Art 13(3); Art 3(23)-(24)	Home door control; guest access; foreseeable use on small-office doors
Expected time in use	[Years, from Template 3]	Art 13(3)	10 years
Operational environment	[Environment, user capability, administrator, network exposure, physical access]	Art 13(3)	Exterior door; consumer owner; home Wi-Fi; device physically reachable by passers-by

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Attacker profile	[Attackers assumed and excluded, with reasons]	Commission FAQ section 4.1	Remote opportunist; local attacker in BLE range; intruder with physical access. No capable-adversary assumption for a consumer product
Assets	[Data, functional and security assets]	BSI TR-03183-1 RH_RA.1	Data: app keys, guest codes, access log. Functional: actuator, update path. Security: root of trust, signing keys
Architecture and data flows	[Diagram reference with trust boundaries]	Annex VII pt 2(a)	DFD-L2 [version]
Component inventory	[SBOM reference and due-diligence status]	Art 13(5); recital 34	SBOM [ref]; BLE stack and TLS library reviewed
Risk rating scale	[Impact on C, I, A by likelihood]	BSI TR-03183-1 RH_RA.1.2	Impact 1-5 by likelihood from exposure and access needed
Acceptance criteria	[Per-product criteria in terms of harm to users, data and connected systems]	Guidance paras 156-163	No residual risk allowing unauthorised unlock without physical attack on the lock body

Part B: threat register

Threat ID and asset	Attack path	Rating	Requirement and control	Residual risk and treatment
T-01: replay of a captured BLE unlock (actuator)	Attacker in BLE range records and resends a command	Integrity high; likelihood medium	2(f): signed commands with nonce; stale commands rejected and logged	Low; tested by negative test NT-12
T-02: guest code used after expiry (guest codes)	Lock clock drift or offline lock keeps an expired code	Integrity high; likelihood low	2(d): expiry enforced on the lock with signed time sync	Low; Annex II pt 5 tells owners to revoke guests in the app
[T-ID: threat (asset)]	[Path]	[Impact; likelihood]	[Item: control]	[Level; treatment]

Part C: Annex I Part I applicability

One row per requirement; Part I point (1) plus the thirteen point (2) items. Cells show illustrative L2 entries.

Requirement	Applies?	How met / design measure	Evidence	Justification if not applicable
(1) Appropriate level of cybersecurity based on the risks	Yes (absolute)	Threat model and risk treatment selecting the (2) (a)-(m) controls	RA-L2 change log; DFD-L2	Cannot be disapplied
(2)(a) No known exploitable vulnerabilities	Yes	Release SBOM checked against EUVD, CVE and KEV; all available patches applied	Gate record; scan report; VEX	[ ]

Requirement	Applies?	How met / design measure	Evidence	Justification if not applicable
(2)(b) Secure by default, with reset to original state	Yes	Per-unit pairing code; no default account; factory reset to baseline	Default-config export; reset test	[ ]
(2)(c) Security updates, automatic by default where applicable, with opt-out	Yes	Signed firmware; anti-rollback; automatic updates on, postpone and opt-out in the app	Update design note; update tests	[ ]
(2)(d) Protection from unauthorised access; report possible unauthorised access	Yes	Account MFA for owners; time-limited guest keys; lockout; failed-attempt alert	Access model; negative tests	[ ]
(2)(e) Confidentiality of stored, transmitted and processed data	Yes	TLS 1.3 to the cloud; encrypted BLE session; keys in secure storage	Cryptographic inventory; downgrade test	[ ]
(2)(f) Integrity of data, commands, programs and configuration; report corruption	Yes	Verified boot; signed commands with nonce; integrity alert	Boot-chain test; replay test	[ ]
(2)(g) Data minimisation	Yes	Access log kept [n] days; telemetry off by default	Data inventory; retention schedule	[ ]

Requirement	Applies?	How met / design measure	Evidence	Justification if not applicable
(2)(h) Availability of essential functions, also after an incident; DoS mitigation	Yes	Keypad and BLE unlock work without the cloud; BLE rate limiting	Cloud outage test; stress report	[ ]
(2)(i) Minimise impact on other devices and networks	Yes	Emitters limited to cloud link, update check and NTP; retry back-off	Emitter inventory; port scan	[ ]
(2)(j) Limit attack surfaces, including external interfaces	Yes	BLE advertising only during pairing; debug ports locked by fuse	Interface inventory; debugger attach test	[ ]
(2)(k) Exploitation mitigation	Yes	Hardened build flags; memory protection unit separation; input validation	Compiler-flag evidence; fuzzing report	[ ]
(2)(l) Logging of relevant internal activity, with user opt-out	Yes	Unlock, key issue, failed-auth and update events logged; opt-out documented with events that persist	Event catalogue; opt-out test	[ ]
(2)(m) Secure erase; secure transfer where possible	Erase yes; transfer no	Factory reset deletes keys, log and cloud binding	Write-erase-read test	Transfer: no transferable data; the new owner re-creates the access list. Erase steps in Annex II pt 8(d)

Part D: Annex I Part II

Requirement	Applies?	How applied	Evidence
Annex I Part II points 1-8 (vulnerability handling)	Yes; all apply (no risk-assessment chapeau; pt 2 is "in relation to the risks posed")	[Statement of how each process is applied, as Art 13(3) requires]	SBOM, CVD policy (Template 7), update design note, reporting runbook (Template 8)

Part E: residual-risk acceptance

Field	What to enter	Basis
Decision right	[Role accepting residual risk; it must be named]	Governance
Criteria met	[Which acceptance criterion each residual risk meets]	Guidance paras 156-163
Other means relied on	[Intended-use limits or user information, with Annex II pt 5 reference]	Recital 55
Signature	[Name], [role], [date]	Art 13(3)

Cost, commercial strategy and internal risk tolerance are not valid reasons (guidance paras 156-163). Risk cannot be shifted to users to cover a design shortcoming; an unaddressable risk means changing the design, functionality or intended purpose.

Part F: update triggers

- [ ] Security-relevant release, including changed interfaces, dependencies, update path or RDPS boundary
- [ ] Newly known vulnerability in the product or a component
- [ ] Newly known threat or attack technique for the product class
- [ ] New findings from security tests, reviews or penetration tests (Annex I Part II pt 3)
- [ ] Substantial-modification assessment at the release gate (Template 10)

Each update is a new version with a change log. Keep all versions placed on the market (Art 13(13)).

Common mistakes

- Marking (2)(a), (b), (d) or (l) not applicable without strong reasons. Drafting bodies treat them as near-universal.
- Writing "accepted, business decision" as a residual-risk treatment. It fails; name the criterion, the control and the re-test trigger.
- Leaving the manufacturer-built backend out because "it is cloud". Assess both ends of each RDPS boundary.
- Treating scanner hits as risk. Apply reachability and record VEX justifications.
- Updating on a calendar only. Wire the triggers into PSIRT and release processes.

Template 2 · v1.0 · 31 Oct 2026 · Not legal advice; confirm wording against the Official Journal text before use.